

Consent becomes an enterprise control

Architecture POV

A pluggable reference architecture for Indian banks translating DPDP intent into operational decisions, propagation and evidence.

Architecture conclusion

Separate identity, authorization, consent and enforcement. Keep the consent platform replaceable. Make decisions available through APIs and distribute state changes through events.

Five design principles

1 Purpose before product

Model purposes, data, recipients, basis and evidence first.

2 Consent at runtime

Use consent during processing, not only during audit.

3 Events for change

Treat withdrawal and expiry as enterprise events.

4 Loose coupling

Shield channels from consent-vendor interfaces.

5 Evidence by design

Correlate notice, action, decision and downstream response.

Scope boundary

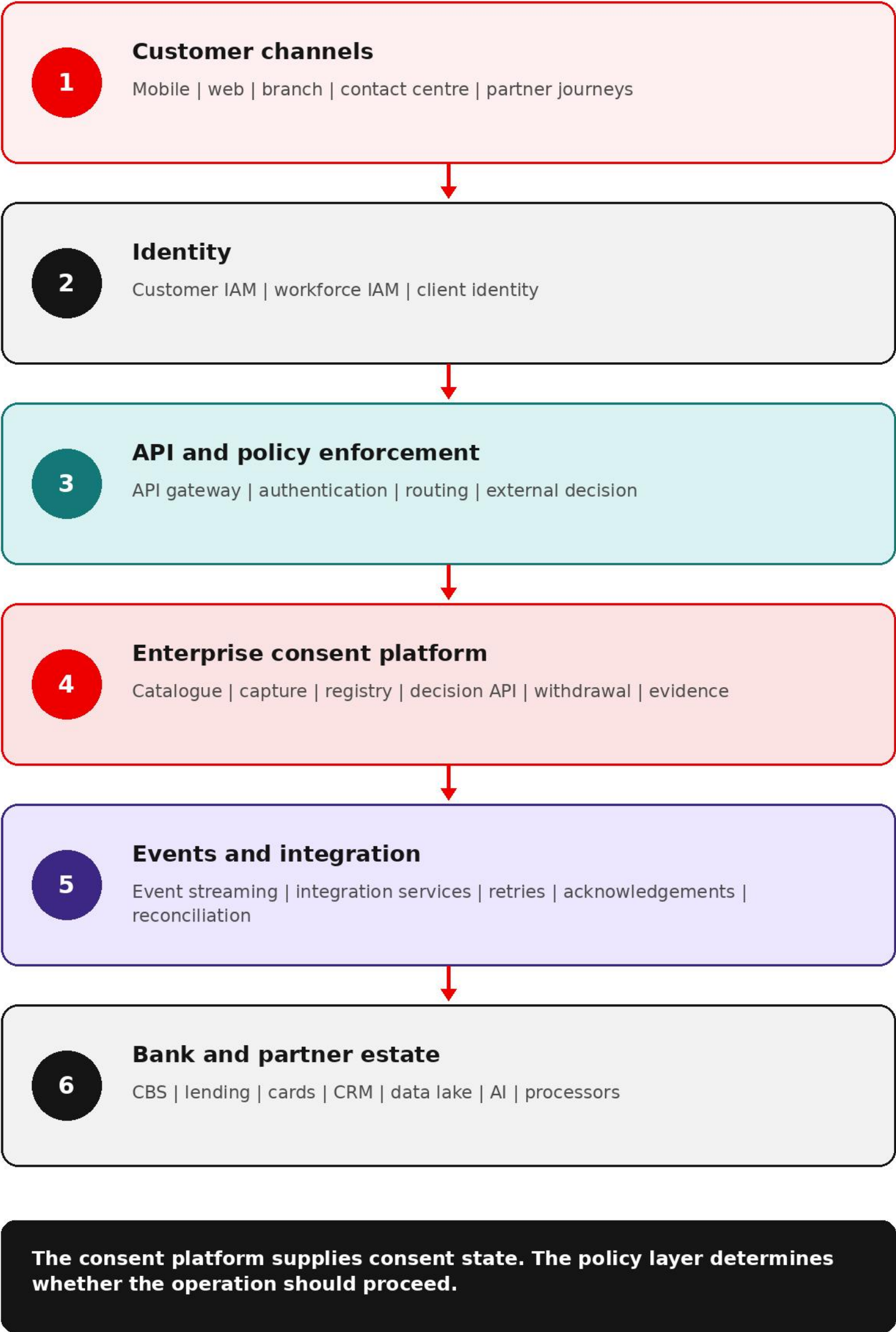
This enterprise pattern complements specialised Account Aggregator consent flows. It also supports processing and retention grounds other than consent.

The goal

A reliable consent state that every authorised channel and processing system can consume and enforce.

Logical architecture

A consent control plane connects customer choice to API decisions, banking systems and auditable downstream action.



Place each product in the right role

OpenShift and Red Hat components enable the platform, enforcement and integration pattern; they do not replace the consent system of record.

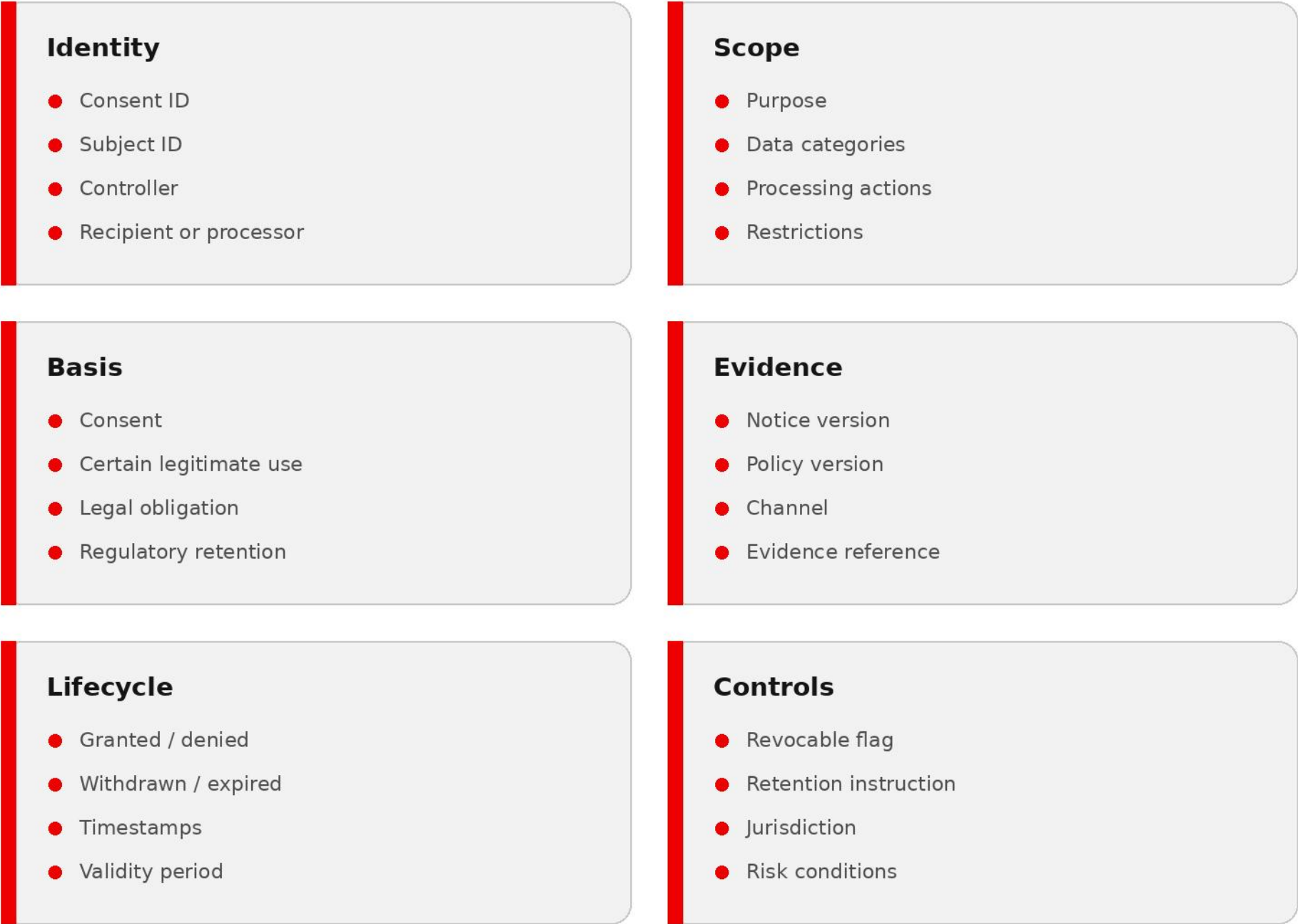
Architectural role	Required capability	Technology option
Application platform	Run adapters, policy services and new applications	OpenShift
Identity	Authenticate customers, workforce and calling clients	RHBK or existing IAM
API enforcement	Secure, route and invoke external consent decisions	RH Connectivity Link
Consent record	Manage purpose, notice, status, lifecycle and evidence	Commercial CMP or custom service
Integration	Connect channels, CBS, lending, CRM and partners	Application Foundations / Camel
Events	Distribute grant, update, expiry and withdrawal	AMQ Streams for Apache Kafka
Security	Protect platform, workloads, secrets and runtime	ACS and OpenShift controls
Evidence	Correlate decisions and operational response	Audit, observability, SIEM and GRC

Architectural boundary

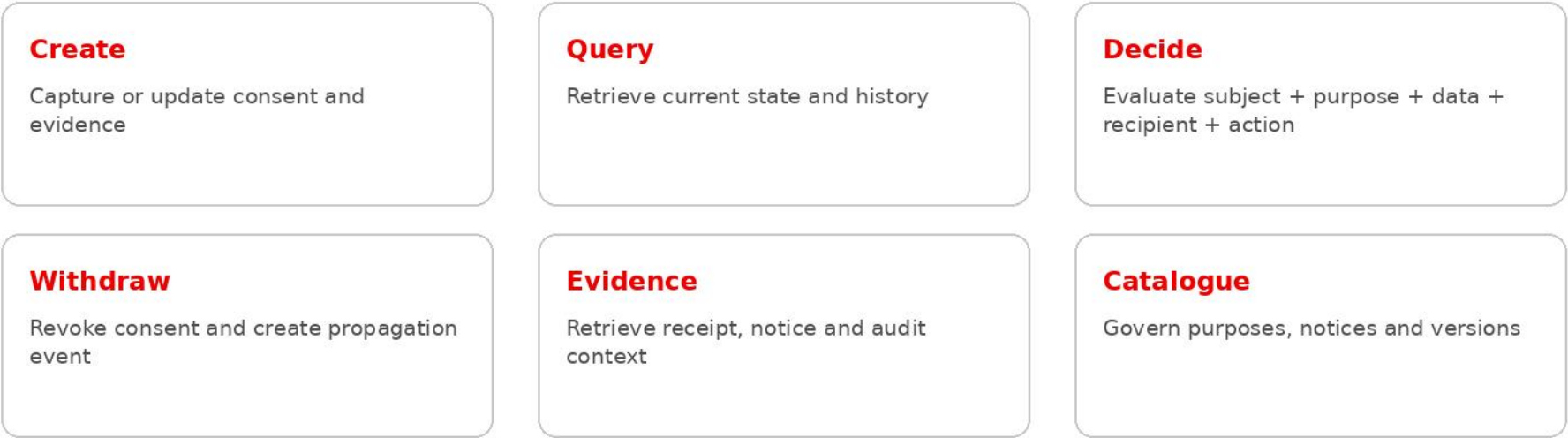
OAuth consent and enterprise privacy consent address different decisions. A bank can keep OneTrust, Securiti, an India-focused product or a custom service pluggable behind stable bank-owned interfaces.

Model consent as evidence, not a flag

The canonical record must answer who, what, why, with whom, under which notice, for how long and on what processing basis.

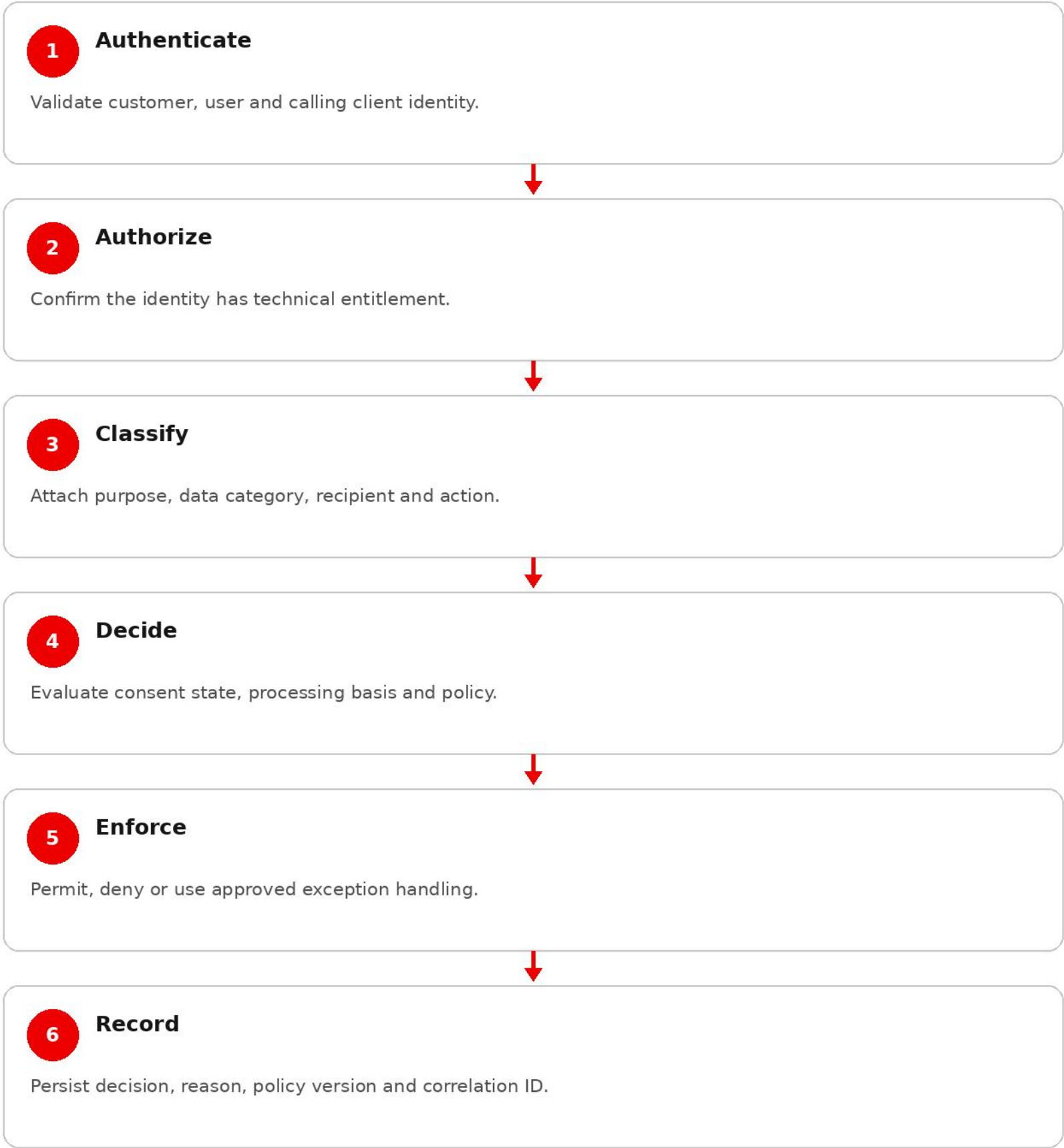


Minimum service interfaces



Decide and enforce at runtime

Authentication alone is not proof of consent. A transaction should carry enough context to reach an explainable permit or deny decision.

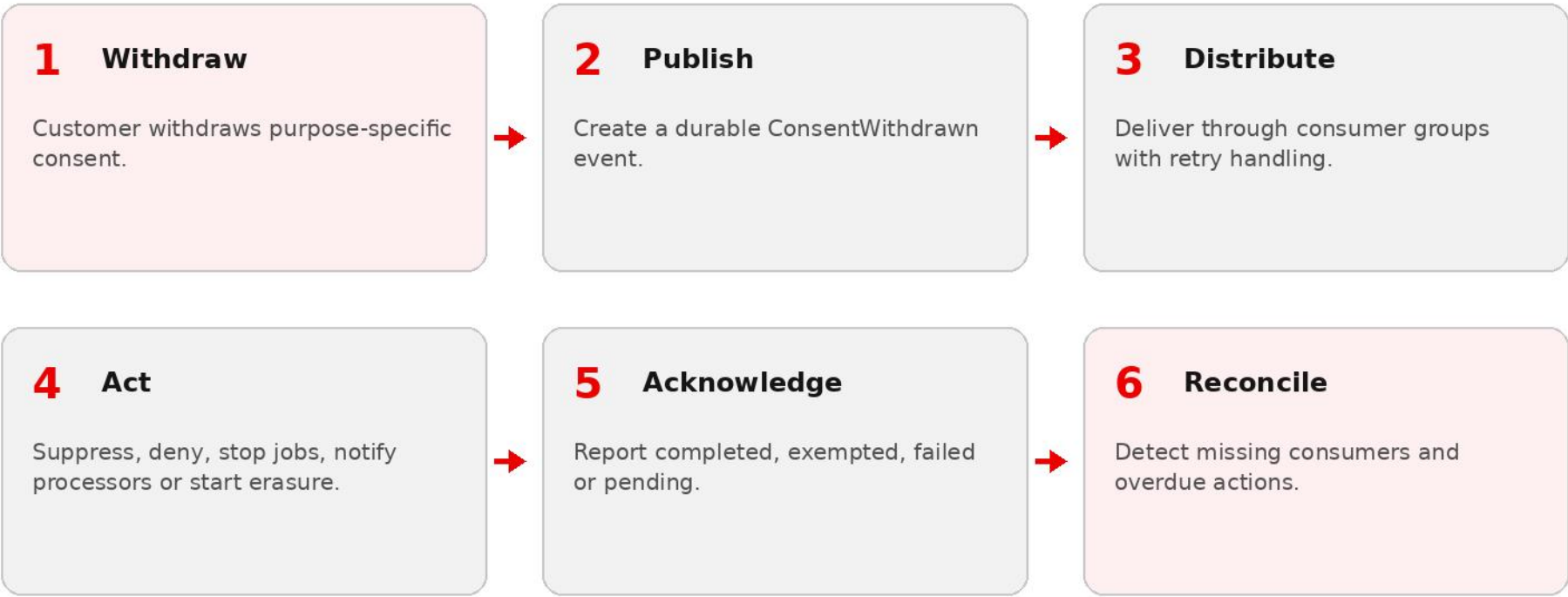


Example decision context

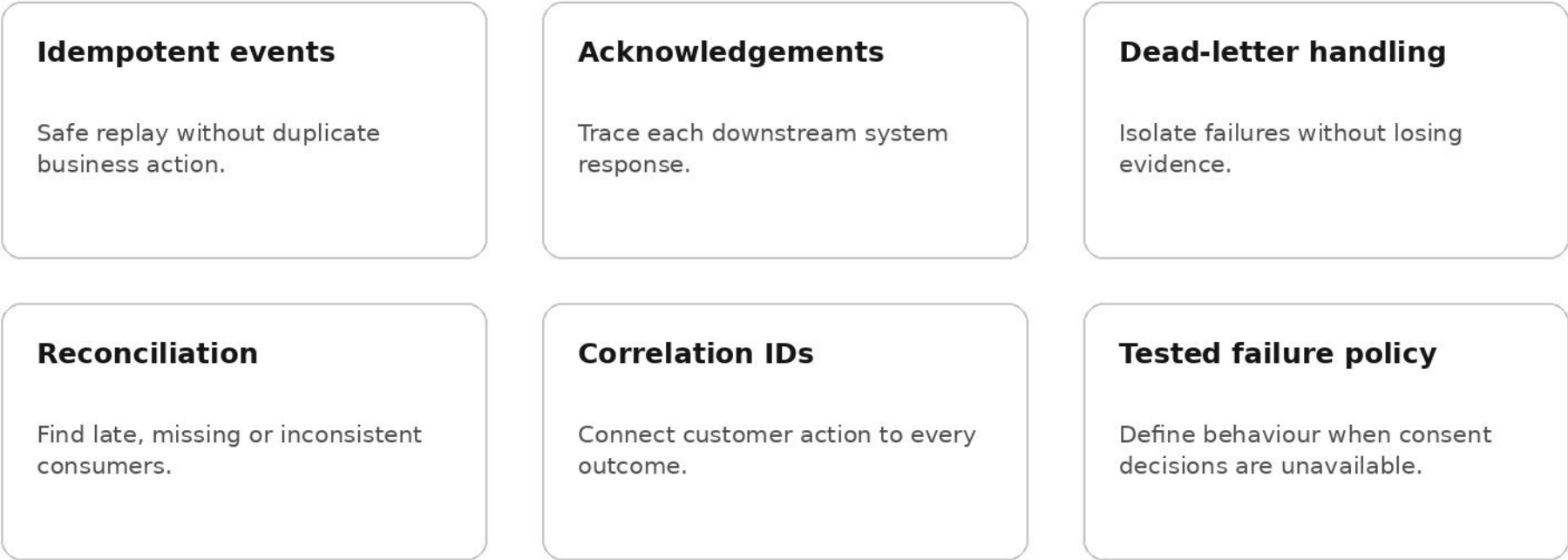
Subject: CUST-12345	Action: SHARE
Requester: FINTECH-X	Basis: CONSENT
Purpose: CREDIT-ASSESSMENT	Consent: ACTIVE + MATCHED
Data: TRANSACTION-HISTORY	Decision: PERMIT

Withdrawal is an enterprise event

A registry update becomes operational only when affected processing stops - or an explainable non-consent basis is applied.



Reliability controls



Retention is policy-driven

Withdrawal does not automatically erase every record. Statutory, contractual or fraud-control obligations may require continued processing or retention. Record the basis, limit the use and preserve an explainable outcome.

Choose build, buy or hybrid deliberately

The key evaluation is not whether a product can show a checkbox; it is whether the bank can operationalise consent at scale.

1

Functional depth

Purpose and notice versioning, capture, receipts, rights and grievance workflows

2

Decision integration

Low-latency API, bulk query, webhooks, events and policy context

3

Enterprise fit

IAM, API gateways, Kafka, CRM, data platforms, legacy and partners

4

Regulatory fit

DPDP terminology, banking use cases and processing-basis modelling

5

Non-functional

Throughput, latency, HA, DR, observability, support and upgrades

6

Security

Residency, encryption, keys, segregation, audit and assurance

7

Portability

Exportable records and bank-owned API and event contracts

8

Vendor maturity

BFSI references, viability, roadmap and implementation ecosystem

Recommended pattern

Use a hybrid approach when mature privacy workflows are needed quickly but the bank wants control of enforcement and integration. Place the product behind bank-owned API and event contracts.

Decision shortcut

Buy

Prioritise speed, mature workflows and vendor accountability.

Build

Prioritise differentiation, control and integration flexibility.

Hybrid

Combine mature consent operations with bank-owned enforcement.

Move from inventory to assurance

Start with one measurable journey, prove the complete control loop, then scale across lines of business.



Ten discovery questions

- 01** Where is consent captured today?
- 02** Can the exact accepted notice be reproduced?
- 03** Which activities rely on consent or another basis?
- 04** How are offline and legacy consents reconciled?
- 05** Can applications validate consent before processing?
- 06** How is withdrawal propagated downstream?
- 07** Which retention duties override erasure?
- 08** Who owns purposes and notice changes?
- 09** What latency and propagation objectives apply?
- 10** Is the preference buy, build or hybrid?

Suggested success measures

Coverage of priority purposes | complete evidence rate | decision latency and availability | withdrawal propagation time | failed acknowledgements | reconciliation rate | audit retrieval time

Terminology note

Under DPDP, Consent Manager is a defined registered role. Call the internal bank component an Enterprise Consent Management Platform unless it fulfils that statutory role.

About this Architecture PoV

A personal professional point of view connecting regulatory intent, enterprise architecture and consent-aware processing at scale.

Purpose

This PoV explores how regulatory intent around consent can be translated into an enterprise architecture capable of making, enforcing and evidencing consent-aware processing decisions at scale.

Sumit Mukherjee

Enterprise Architecture | Cloud Native | Modernization | Security

Explore more Architecture Points of View

<https://summu1985.github.io/>

Version 1.0 · September 2026

References and scope

1

Digital Personal Data Protection Act, 2023

<https://www.meity.gov.in/static/uploads/2024/06/2bf1f0e9f04e6fb4f8fef35e82c42aa5.pdf>

2

Digital Personal Data Protection Rules, 2025

<https://www.meity.gov.in/static/uploads/2025/11/53450e6e5dc0bfa85ebd78686cadad39.pdf>

3

RBI Guidelines on Digital Lending

<https://www.rbi.org.in/commonman/english/scripts/FAQs.aspx?Id=3413>

4

RBI NBFC Account Aggregator Master Directions, 2016

https://systemhealth.rbi.org.in/Scripts/NotificationUser.aspx_Id%3D12378%26Mode%3D0.html

Disclaimer

This document presents an architecture point of view and is not legal or regulatory advice. Organisations should validate applicability and obligations with their legal, privacy, compliance and risk functions.